SpendWise — AWS Backend Specification

Detailed API contract, DynamoDB design, Cognito authorization, S3 and infrastructure

What this document controls

Use this after the UI exists. It defines the serverless backend and the security model. Infrastructure code still needs to be deployed and tested in your AWS account.

Never make personal finance records public to simplify a demo. Backend ownership checks are mandatory.

COPY THE FULL PROMPT BELOW INTO ANTIGRAVITY

Use this prompt as one message. Let Antigravity inspect the repository, make the requested changes, run checks, and report what it actually completed. Do not skip the checkpoints.

```
ROLE
You are an experienced AWS serverless engineer. Build a secure backend for the existing SpendWise frontend. Work only in the

REQUIRED STACK
API Gateway HTTP API, AWS Lambda Node.js 22 (ES modules), DynamoDB, AWS SDK v3, Cognito User Pools/JWT authorization, AWS SAM

AUTHENTICATION
Configure Cognito User Pool and an app client suitable for browser-based sign-in. Protect personal endpoints with JWT authori

API CONTRACT
- GET /health — public health check, no private data.
- GET /transactions — authenticated; current user's transactions with date/category/type filters and pagination.
- GET /transactions/{transactionId} — authenticated; only owner's record.
- POST /transactions — authenticated; create a record for the authenticated user.
- PATCH /transactions/{transactionId} — authenticated; update only permitted fields on owner's record.
- DELETE /transactions/{transactionId} — authenticated; delete only owner's record.
- GET /budgets?month=YYYY-MM — authenticated; only user's budgets for month.
- POST /budgets — authenticated; create an overall or category budget.
- PATCH /budgets/{budgetId} — authenticated; update own budget.
- DELETE /budgets/{budgetId} — authenticated; delete own budget.
- GET /analytics/summary?month=YYYY-MM — authenticated; return analytics derived only from that user's transactions.
- POST /uploads/presign — optional authenticated receipt upload URL generation.

DATA CONTRACT
Transaction: transactionId, userId (derived on server), description, amount, type, category, transactionDate, paymentMethod,
Budget: budgetId, userId (derived on server), month, category (use a documented sentinel for overall budget), limitAmount, cr
Amounts must be finite positive numbers. Define money precision consistently; avoid floating-point surprises by validating de

DYNAMODB DESIGN
Design partition/sort keys or a table/index strategy for querying a user's records by date and budgets by month. Document key

SECURITY
- Validate JSON, route parameters, query parameters, enum values and amounts.
- Return consistent JSON and appropriate status codes: 400 validation, 401 unauthenticated, 403 forbidden if applicable, 404
- Never reveal whether another user's guessed record ID exists.
- Restrict CORS to configured frontend origin and required methods/headers.
- Use least-privilege IAM policies for DynamoDB and S3.
- Keep private data out of logs; log request IDs and safe error summaries.
- S3 bucket must block public access and enforce encryption where available.
- Presigned URL should be short-lived, constrained to allowed content types, and use unique object keys scoped to the authent
- Do not expose AWS credentials or internal exception messages.

INFRASTRUCTURE
Create `backend/template.yaml` with Lambda, API Gateway, DynamoDB, Cognito configuration or clearly documented parameters, S3

DELIVERABLES
- Working handler code split into understandable functions.
- Input validation and consistent response helpers.
- Unit tests for validation, calculations, authorization assumptions and handlers where feasible.
- `backend/README.md` with exact deployment steps, Cognito setup, API contract, environment settings, CORS and cleanup instru
- `.env.example` contains placeholders only.
```

Before finishing, run available tests and `sam validate --lint` if SAM CLI exists. State which checks actually ran and what needs real AWS credentials/account configuration. Do not claim deployed resources merely because the template exists.